

Défense Périphérique Avancée (Pare-feu Windows & IPsec)

Objectifs :

- Comprendre la nécessité du pare-feu local (Host-Based Firewall) en approche Zero Trust.
- Maîtriser l'architecture des profils du Pare-feu Windows Defender.
- Identifier et bloquer les ports utilisés pour les mouvements latéraux (Ransomwares).
- Appréhender l'Isolation de Domaine via IPsec (Règles de sécurité de connexion).

1. Le paradigme "Zero Trust"

La sécurité réseau reposait sur un modèle périmétrique. On déployait des pare-feux très coûteux entre Internet et le réseau local (LAN), mais le trafic interne était libre.

1.1 Pourquoi le pare-feu de bordure est obsolète

Aujourd'hui, l'attaquant ne vient plus d'Internet en forçant le pare-feu. Il entre de manière légitime ou détournée :

- **Le Phishing** : L'utilisateur clique sur une pièce jointe, le malware s'exécute directement à l'intérieur du réseau local (Tier 2).
- **Le Télétravail (VPN)** : Un PC portable personnel compromis se connecte via VPN et propage un ver sur le réseau de l'entreprise.
- **Le Shadow IT / Périphériques vérolés** : Une clé USB ou un équipement IoT branché sur une prise réseau du bâtiment.

1.2 La solution : Le Host-Based Firewall (HBF)

L'ANSSI et les frameworks modernes (Zero Trust) exigent que la sécurité soit ramenée au plus près de l'actif. **Chaque serveur et chaque poste de travail doit posséder son propre pare-feu activé et configuré de manière stricte.** Même si deux PC sont branchés sur le même switch dans le même bureau, ils doivent se considérer comme hostiles.

2. Architecture du Pare-feu Windows Defender

Le Pare-feu Windows avec fonctions avancées (WFAS) c'est un moteur de filtrage de classe entreprise, pilotable par GPO.

2.1 Les trois Profils de Connexion (NLA)

Windows utilise le service Network Location Awareness (NLA) pour détecter automatiquement sur quel type de réseau il est branché, et applique le profil correspondant :

1. **Profil de Domaine** : Appliqué **uniquement** si la machine arrive à s'authentifier de manière sécurisée auprès de son Contrôleur de Domaine Active Directory. C'est le profil de confiance.
2. **Profil Privé** : Appliqué lorsque l'utilisateur déclare explicitement un réseau comme "Réseau de bureau" ou "Réseau domestique" (sans AD). Utilisé derrière un routeur NAT connu.
3. **Profil Public** : Appliqué par défaut sur tout nouveau réseau (Wi-Fi de gare, d'hôtel, 4G). C'est le profil le plus restrictif, bloquant presque tout le trafic entrant.

2.2 La gestion de la fusion des règles (Rule Merging)

Par défaut, le Pare-feu Windows fusionne les règles définies par l'administrateur local avec celles poussées par l'Active Directory (GPO).

- **Vulnérabilité** : Si un administrateur local (ou un malware ayant élevé ses privilèges locaux) crée une règle autorisant le port 4444, le pare-feu l'acceptera, même si la GPO ne le prévoit pas.
- **Exigence ANSSI** : Dans les GPO de Pare-feu appliquées aux serveurs et postes, l'architecte doit configurer le paramètre : **Appliquer les règles de pare-feu locales : Non**. La machine n'obéira alors qu'à la GPO du domaine, sanctuarisant la matrice de flux.

3. Contrer les Mouvements Latéraux (Micro-segmentation)

Le mouvement latéral est la technique utilisée par un attaquant (ou un ransomware) pour rebondir d'une machine compromise vers le reste du parc.

3.1 Isolation des postes de travail (Client-to-Client)

Sur un réseau d'entreprise sain, un poste de travail (ex: PC Comptabilité) doit communiquer avec :

- Les Contrôleurs de Domaine (DNS, Kerberos, LDAP).
- Les serveurs de Fichiers / Imprimantes (SMB).
- Internet (HTTPS).

Mais un poste de travail n'a aucune raison légitime d'initier une connexion vers un autre poste de travail. Pourtant, c'est exactement ce que font les ransomwares : ils scannent le sous-réseau et utilisent des protocoles natifs pour infecter les PC voisins.

3.2 Les ports critiques à verrouiller

Pour stopper l'hémorragie, des règles entrantes (Inbound) strictes doivent être déployées pour bloquer ces protocoles entre les machines de même niveau (Tier) :

- **SMB (TCP 445) :** Utilisé par WannaCry, Petya, et PsExec. Ne doit être ouvert en entrée QUE sur les vrais serveurs de fichiers.
- **RPC (TCP 135 & Ports dynamiques 49152-65535) :** Utilisé par WMI pour l'exécution de code à distance.
- **WinRM (TCP 5985/5986) :** L'administration PowerShell à distance. Doit être restreint pour n'accepter des connexions que depuis l'IP spécifique du Serveur d'Administration (Bastion).

4. L'Isolation de Domaine (IPsec)

Que faire si un attaquant amène son propre PC portable piraté et le branche physiquement sur une prise réseau du siège social ? Même avec de bons VLAN, il pourrait scanner les serveurs.

4.1 Les Règles de sécurité de connexion

Le Pare-feu Windows intègre un moteur **IPsec**. Contrairement aux règles classiques qui filtrent par IP ou par Port, IPsec filtre par **Identité Cryptographique**.

L'architecte déploie une "Règle de sécurité de connexion" (Connection Security Rule) qui exige une **Authentification Kerberos**. Le comportement du réseau change radicalement :

1. Le serveur reçoit une demande de connexion TCP (ex: accès au port 445).
2. Avant même d'accepter le paquet TCP, le serveur exige que le client prouve cryptographiquement qu'il est membre du domaine Active Directory.
3. Si le client est le PC du pirate (qui n'est pas joint au domaine), la connexion est détruite

au niveau de la carte réseau. Le pirate verra le serveur comme "éteint" (Drop).

4.2 L'Isolation Logique vs Physique

IPsec permet de créer un "Domaine Virtuel Sécurisé" au-dessus du réseau physique. On peut aller très loin en exigeant que non seulement la machine soit membre du domaine, mais qu'elle appartienne à un groupe de sécurité spécifique (ex:

Autorisés_Accès_Serveurs_Critiques), chiffrant ainsi les flux de bout en bout (ESP) contre les écoutes sur le réseau local.